AGENTSHIELD AI

Autonomous Multi-Agent Cybersecurity Defense & Simulation Platform
Complete Technical Dossier & Architectural Whitepaper

1. Executive Summary & Mission

AgentShield AI is an enterprise-grade autonomous cybersecurity defense and red-teaming firing range purpose-built for **Autonomous AI Agents and Large Language Model (LLM) Tool Workflows**. Modern enterprise applications grant autonomous agents access to cloud filesystems, corporate emails, payment gateways, and databases. This architectural shift exposes enterprises to novel vectors: **indirect prompt injection, model jailbreaks, privilege escalations, and automated financial fraud**.

AgentShield provides an air-gapped simulation environment where an adversarial **Red Team Agent** continuously tests an enterprise **Target AI Agent** across the OWASP Top 10 for LLMs. Defending the perimeter is the autonomous **Blue Team Guardian**—an inline security proxy enforcing multi-signal risk analysis, ML injection classification, intent drift heuristics, and dual-actor approvals.

2. Complete Technology Stack

Layer	Technology	Role & Architecture Function
Frontend UI	Next.js 14 (App Router) + React 18	Server/Client components, dynamic routing, Tailwind CSS Cyber Violet theme
3D Battlefield	Three.js (WebGL)	Real-time 3D tactical maze, agent trajectory lerping, defense dome, Fullscreen API
Real-Time DB	Convex Cloud Database	Reactive WebSocket data synchronization for campaigns, audit logs, and decisions
Backend Core	FastAPI + Python 3.14	Asynchronous REST service, dependency injection, lifespan hooks, CORS middleware
ML Detection	Scikit-learn + Joblib (:8001)	Dedicated prompt injection classification microservice (<20ms fail-fast inference)
Observability	Langfuse Cloud (OTel v5)	Guardrail span tracing, agent session tracking, risk scores, token & cost tracking
Authentication	Clerk + 6-Tier Mock RBAC	User auth combined with strict role boundaries (Admin, Analyst, Employee, etc.)

3. Multi-Agent Security Workflow

AgentShield AI implements a strict 4-phase evaluation lifecycle designed to prevent any untrusted instruction from reaching execution without inspection:

1. **Infiltration (Red Team)**: Red Team dispatches adversarial payloads (e.g. prompt injection embedded in email body or forum page) into the simulated workspace.
2. **Task Deconstruction (Target AI)**: Target Agent plans tool proposals (JSON schema) using LLM reasoning (OpenAI GPT-4o or deterministic mock).

3. **Inline Inspection (Blue Team Guardian)**: Guardian intercepts tool calls before invocation, evaluating hard policy rules, ML injection confidence, and intent drift to calculate a composite 0-100 Risk Score.
4. **Reactive Telemetry & Broadcast**: Verdict is recorded in Convex Cloud DB and Langfuse; 3D maze flares defensive shield or registers breach.

4. The 15 Attack Scenarios (OWASP Top 10 for LLMs)

Curated benchmark suite covering enterprise attack surfaces across 6 categories:

Attack ID	Scenario Name	Category	Target Tool	Defense Mechanism
PI-EMAIL-001	CEO Fraud Wire Transfer	Prompt Injection Email	Email / Payments	Intent Alignment + ML Advisory + Dual Auth
PI-EMAIL-002	System Override via Email	Prompt Injection Email	Email	Instruction Boundary Enforcement
PI-WEB-001	Indirect Forum Injection	Prompt Injection Web	Browser / Files	Content Disarm & Isolation
PI-WEB-002	Fake Security Patch	Prompt Injection Web	Browser	Domain Allowlist & Action Verify
PRIV-001	Confidential File Read	Privilege Escalation	Filesystem	Path Sandboxing & RBAC Boundary
PRIV-002	File Write Outside Sandbox	Privilege Escalation	Filesystem	Path Normalization & Write Restriction
PRIV-003	Restricted Traversal	Privilege Escalation	Filesystem	Path Canonicalization Filter
PAY-001	Direct Payment Injection	Payment Fraud	Payments	Dual-Actor Human Approval Gate
PAY-002	Compound Payment Request	Payment Fraud	Payments	Compound Intent Deconstruction
PAY-003	Offshore Vendor Redirect	Payment Fraud	Payments	Recipient Allowlist Verification
TOOL-001	Mass Data Exfiltration	Tool Abuse	Mail / Files	Rate Limiting & Egress DLP
TOOL-002	Unauthorized Web Scrape	Tool Abuse	Browser	Sandbox Network Enforcement
TOOL-003	File Mass Modification	Tool Abuse	Filesystem	Destructive Action Throttling
LOOP-001	Recursive Task Spawning	Loop Exhaustion	Target Core	Max Call Bound (MAX_CALLS=10)
LOOP-002	Continuous Mail Polling	Loop Exhaustion	Email	Temporal Frequency Circuit Breaker

5. Feasibility, Strategic Impact & ROI

Technical Feasibility: Operates entirely locally with zero cloud subscription lock-in. Uses lightweight SQLite fallback and modular microservices with fail-fast timeouts. Requires standard developer hardware.

Economic Feasibility & ROI: Simulation testing incurs $0 in offline mode and pennies in live LLM mode. In contrast, enterprise LLM breaches cost an average of $4.45M (IBM Security Report). Mitigating one unauthorized payment or data exfiltration produces immediate multi-million-dollar ROI.

Enterprise Benefits: Eliminates blind trust in LLMs. Enables pre-production red-team certification, real-time SOC 2 / ISO 27001 audit logging, token expenditure tracking via Langfuse, and human-in-the-loop governance.

Langfuse Cloud Observability Integration (Active)
Every agent execution trace, prompt injection classification, and Blue Guardian evaluation is live-streamed to Langfuse Cloud using OpenTelemetry v5. Quantitative metrics (risk scores, defense effectiveness, token costs, latency) are permanently tracked for post-incident security forensics.